

Google Dorks

: 구글 검색 연산자를 통한 정보 노출 진단 도구

무엇을 할 수 있는가?

- 검색엔진에 의해 색인된 민감 정보 노출 여부 진단
- 잘못 공개된 백업 파일·설정 파일·디버그 페이지 파악
- 검색엔진 색인 정책의 오류 확인

방어자가 활용하는 방식

1. 검색엔진에서 내 사이트 관련 색인 내용 파악
2. 민감한 파일이 노출되는지 확인
3. 디렉터리 **listing** 누락·로깅 파일 공개 여부 검사
4. **noindex/meta** 설정이 제대로 동작하는지 확인

****noindex/meta** : 검색엔진이 웹페이지를 어떻게 다룰지 지시하는 설정

파라미터 예시 :

파라미터	기능	예시	설명
site	특정 도메인	site:github.com "api key"	GitHub 도메인 내에서 "api key"라는 문자열이 포함된 공개된 코드를 찾습니다.
intitle	문서나 페이지의 타이틀	intitle:"Index of /backup"	웹 서버의 디렉토리 목록(Index of) 중, 타이틀에 /backup 이라는 단어가 포함된 페이지를 찾습니다. (백업 파일 노출 가능성 확인)
filetype	파일의 확장자	filetype:xlsx "비밀번호"	웹에 공개된 엑셀(xlsx) 파일 중에서 파일 내용에 "비밀번호"이라는 문자열이 포함된 문서를 찾습니다.
intext	페이지안의 문자열	intext:"ssh private key" -github	웹페이지 본문(텍스트) 내에서 "ssh private key"라는 정확한 문자열을 포함하고, GitHub는 제외한 페이지를 찾습니다.
inurl	URL안의 단어	inurl:admin login	URL 경로에 admin 이라는 단어가 포함되어 있고, 페이지 내용에 login 이라는 단어가 있는 페이지를 찾습니다. (관리자 로그인 페이지 추정)

실습 전 주의사항 !

검색은 자유, 클릭은 신중하게 !

결과만 보고 '뒤로 가기'

시나리오 1: 디렉터리 리스팅 (Directory Listing) 취약점 찾기

웹 서버 설정 미흡으로 파일 목록이 적나라하게 보이는 서버를 찾습니다.

검색어 (Dork):

`intitle:"Index of /backup"`

실습 포인트:

검색 결과에 들어가 보면 웹사이트 디자인이 없고, 파일 폴더 트리(Tree) 구조가 그대로 보입니다.

여기서 `backup.zip`이나 `web.config` 같은 중요 파일이 보이면 바로 서버 탈취가 가능합니다.

시나리오 2: 특정 타겟(Target) 정밀 정찰

특정 사이트(예: 대학 사이트) 내에서만 정보를 찾고 싶을 때 **site** 연산자를 씁니다.

검색어 (Dork):

site:ac.kr filetype:pdf "대외비"

실습 포인트:

ac.kr(국내 대학) 도메인 내에서 **pdf** 파일이면서 대외비라는 단어가 들어간 것을 찾습니다.

학생들의 주민등록번호나 전화번호가 포함된 신청서가 구글에 돌아다니는 경우가 많습니다. (개인정보 유출 실습)

<https://www.exploit-db.com/google-hacking-database>